

ORPHEUS



Ministry of Defence

WHITEPAPER

Risk Based Vulnerability Management Using Threat Intelligence and Machine Learning

ORPHEUS

Ministry of Defence

SUMMARY

In 2021 Orpheus was commissioned by the United Kingdom's Ministry of Defence (MOD) to deliver a comprehensive Risk Based Vulnerability Management capability, which we successfully delivered in October 2022.

We are pleased to announce that our advanced vulnerability management capability is now also available to other public and private sector clients.

Orpheus was selected by the UK MOD to develop a next-generation capability due to our previous achievements as a highly accredited Cyber Threat Intelligence company deploying award-winning Machine Learning.

We provided our advanced capability as part of the UK Ministry of Defence's Autonomous Resilient Cyber Defense (ARCD) program to direct predictive and autonomous defence against cyber attacks on military systems.

Orpheus deploys Machine Learning and Threat Intelligence to deliver real time Common Vulnerabilities and Exposures (CVEs) risk scores, and our solution includes the following features:

1. **Is the CVE currently exploited?** We continuously identify whether any CVE is one of approximately 0.5% that are actually exploited;
2. **Likelihood of future exploitation?** Orpheus' Machine Learning predicts which CVEs will be exploited in the future with a proven accuracy of up to 94%;
3. **Orpheus' CVE Risk Score**: dynamically fuses vulnerability, threat, business impacts and CVE risk, providing your organisation with a concise list of vulnerabilities for remediation.

ABOUT ORPHEUS CYBER

Orpheus is a highly accredited cyber threat intelligence company, including by the Financial Conduct Authority and the Bank of England. Our powerful and award-winning technologies collect huge volumes of cyber risk data, which we analyse using Machine Learning and our skilled team to enable you to protect your organisation and your supply chain.

ORPHEUS

Ministry of Defence

WHAT IS A CVE?

A CVE, the acronym for Common Vulnerabilities and Exposures, is a publicly disclosed computer security flaw or vulnerability in a technology that has been identified by security researchers.

After the manufacturer of the technology in which a potential vulnerability is found has reviewed and confirmed it, the vulnerability is assigned a unique identifying number and published online, typically along with a way to address or mitigate it.

The CVE programme is a collection of all publicly known vulnerabilities. The program was established in 1999 and is maintained by the MITRE Corporation, sponsored by the U.S. Department of Homeland Security (DHS). The National Vulnerability Database (NVD), managed by the U.S. National Institute of Standards and Technology (NIST), publishes vendor-agreed CVEs on its website. The number of CVEs identified each year has increased steadily, with an expected 25,000 CVEs to be published in the NVD in 2022 alone.

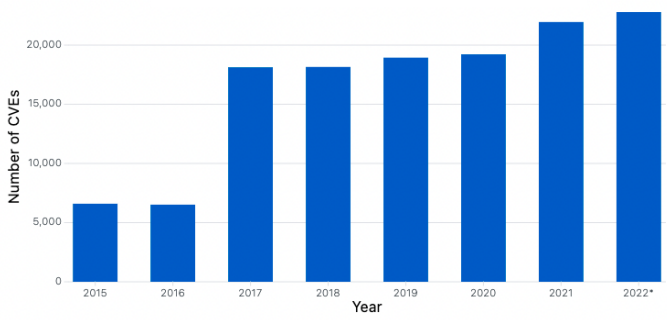
The Common Vulnerability Scoring System (CVSS), owned and managed by the not-for-profit industry group FIRST, assigns a theoretical severity score to each CVE, assuming it is exploited by adversaries. However, it is well known that most CVEs are never actually exploited, which means that organisations focus on mitigating vulnerabilities that may never be a problem.

Malicious actors may attempt to exploit CVEs to perform unauthorised actions on a computer system, such as running code, installing malware, and/or accessing internal systems to steal, destroy, or modify sensitive data.

VULNERABILITY MANAGEMENT CHALLENGES

1. VOLUME

The growing number and complexity of online systems have resulted in a year-on-year increase in published CVEs. The sheer number of vulnerabilities have security teams struggling to keep up with the required patching. As shown below, in 2022 alone it is likely that close to 25,000 CVE's will be published, while in the last 5 years a phenomenal 120,000 CVE's have been publicised by the NVD.



publish_year	n_cves
2015	6,595
2016	6,517
2017	18,113
2018	18,154
2019	18,938
2020	19,216
2021	21,950
2022*	22,793

Fig. 1 Yearly CVEs published by NVD, up until November 2022

2. LACK OF KNOWLEDGE OF WHICH CVE'S ARE ACTUALLY BEING EXPLOITED BY ADVERSARIES

Cyber security professionals understand that the vast majority of CVE's remain purely theoretical as they are never actually exploited by hackers. However, as there is no comprehensive repository identifying which CVE's are actually being exploited all organisations have been focused on trying to mitigate vast numbers of CVE's that are not a problem.

3. CVSS CLASSIFICATION

In an attempt to help security teams prioritise which of their CVE's to patch, the NVD publishes a CVSS score that intends to communicate the theoretical severity of vulnerabilities – should they actually be exploited. CVSS uses a scale from 0 to 10, with 10 being the most severe. It takes into account multiple factors such as the ease of exploitation of the vulnerability and the potential impact on the user's system.

The organisation that manages CVSS, FIRST, warns that "CVSS is designed to measure the severity of a vulnerability and should not be used alone to assess risk." Some of the reasons for this statement are:

- To understand the risk associated with a CVE it is necessary to know if adversaries have the capability and intent to exploit it – i.e. is it being exploited? CVSS does not incorporate understanding of exploitation on an ongoing basis.
- A further key flaw in CVSS scores is that they are assigned when the vulnerability is first disclosed, and are not typically updated as more information becomes available.
- Generally high CVSS scores: 15% of CVEs in the NVD database receive a “critical” severity (i.e. a CVSS score of 9 or higher). In general, CVSS scores skew high, with a median score of 7.5, making it difficult for security teams to prioritise accurately. If everything is urgent, then nothing is.

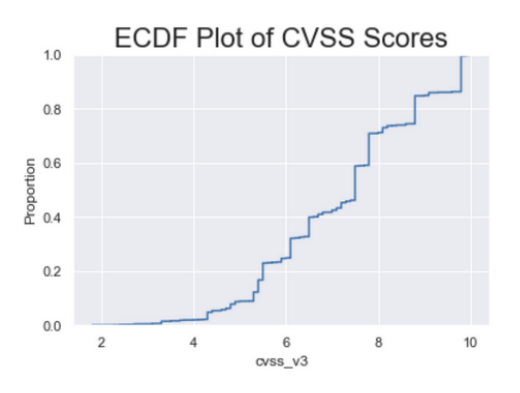


Fig. 2 ECDF Plot of CVSS Scores

“CVSS is designed to measure the severity of a vulnerability and should not be used alone to assess risk.” **FIRST**

4. TIME

To prevent hackers from exploiting vulnerabilities, patching software quickly is crucial. Our research indicates that 15% of exploited vulnerabilities were exploited before the NVD published them or made a CVSS score available. This means that any automated patch prioritisation system reliant on the NVD will leave their users vulnerable for that crucial time window.

The NVD’s publishing delays have been well documented other sources.[1]

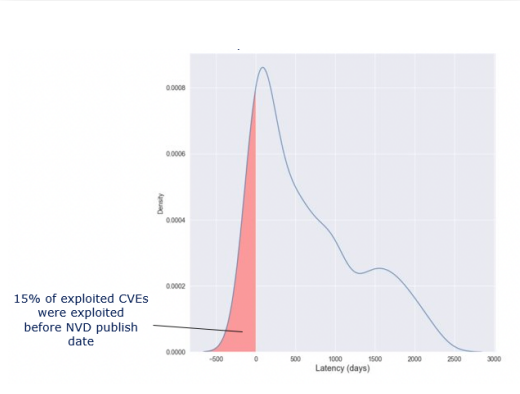


Fig. 3 Distribution of latency between confirmed CVE exploitation and the NVD publish date

5. SYSTEM DOWNTIME

The process of patching is not always smooth. Some patches are notoriously difficult to apply. Disruptions to the business can be costly both in terms of opportunity costs and human capital losses due to system downtime or loss of productivity.

[1] A. Anwar, A. Abusnaina, S. Chen, F. Li and D. Mohaisen, "Cleaning the NVD: Comprehensive Quality Assessment, Improvements, and Analyses," in IEEE Transactions on Dependable and Secure Computing, vol. 19, no. 6, pp. 4255-4269, 1 Nov.-Dec. 2022, doi: 10.1109/TDSC.2021.3125270

THE ORPHEUS SOLUTION

Security teams need timely and accurate information on which CVEs are the most critical to remedy. To achieve this, we need timely and accurate information on the extent to which CVEs are being exploited by malicious actors, as well as leading indicators which allow us to predict future exploitation.

1. GROUND TRUTH: WHICH CVES ARE ACTUALLY EXPLOITED?

To directly observe CVE exploitation, security researchers must write a **detection rule**. This can take various forms, but is typically a hash of a section of code, or a set of behaviours/heuristics, which, if seen, suggests the script is attempting to exploit a particular CVE.

This rule is then applied either to suspected malware samples, or set up on honeypots, to see if it is triggered.

"Detection Rule"	+	"Hits"	=	"Exploitation"

The ground truth of CVE exploitation necessarily underpins any patch prioritisation system, and is a central area of focus for Orpheus. As a component of our CVE scoring we combine the most comprehensive sources of malware samples and honeypot activity into our databases. We also process data from millions of malware samples daily, and malicious activity from a network of over 5000 honeypots.

During our research and development of the Orpheus CVE scoring system our security researchers manually examined our exploitation data, and set minimum thresholds of corroboration before a CVE could be considered definitively exploited. For example, CVEs with single instances of detection rules were often found to be spurious – the result of researcher error, including simple typos in the CVE ID. However, once corroboration thresholds were met, we found 100% agreement between expert manual judgement and our automated CVE exploitation ground truth.

In addition to evaluating the underlying detection rules, Orpheus also uses data from all of the trusted authorities such as the Cybersecurity and Infrastructure Security Agency (CISA), who maintain lists of CVEs that they believe are being exploited.

As of 24th November 2022, we have definitive evidence of exploitation for 1177 CVEs, a mere 0.46% of all existing CVEs.[2] The finding that only a tiny percentage of CVEs are widely exploited has been corroborated by other reputable sources such as Kenna Securities: 2% and Sabottke, Suciu, and Dumitras (2015)[3]: 1.4%.

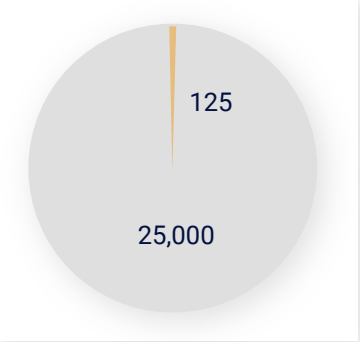


Fig. 4 Exploited CVEs per year

[2] We include CVE-IDs that have merely been reserved by CDNs, and have not yet been published by NVD/MITRE. This is because of the aforementioned publishing delays and the subsequent frequency with which these unpublished CVEs are confirmed exploited. If limiting to CVEs that have been published by the NVD, 0.59% have confirmed exploitation.

[3] Sabottke, Carl F. et al. "Vulnerability Disclosure in the Age of Social Media: Exploiting Twitter for Predicting Real-World Exploits." USENIX Security Symposium (2015).

2. PREDICTION: WHICH CVES WILL BE EXPLOITED IN THE FUTURE?

Once armed with a highly accurate ground truth of exploited CVEs, we trained a Machine Learning algorithm to identify the CVEs with the greatest likelihood of being exploited in the future.

We collected data-sets going back to 2016 to supply a range of features we anticipated would be indicative of future exploitation, including the following:

- Dark Web chatter.
- Online security researcher communities.
- Social media.
- Proof of Concept exploit code published in a large range of repositories.
- Code to detect whether a system has the vulnerability (e.g. Nuclei scanning templates).

Our training and test data comprised ~99,000 CVEs disclosed between 2016 and 2021. We then randomly sampled snapshots of features taken from up to 3 months before exploitation, yielding 716,472 snapshots.

Our model was proven to be highly accurate, with an area under the curve (AUC) value of 0.94 the day before exploitation was confirmed, and 0.89 three months before. AUC is a technical metric that measures a model's ability to correctly order examples, and it can be interpreted as follows:

- An AUC value of 0.50 indicates that the model is no better than random at ordering examples.
- An AUC value of 1.00 indicates that the model can perfectly order examples.
- An AUC value between 0.50 and 1.00 indicates that the model is better than random at ordering examples. The closer the value is to 1.00, the better the model is at ordering examples.

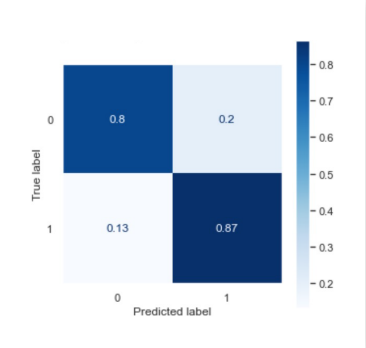


Fig. 5 Confusion Matrix: probability threshold >= 0.25

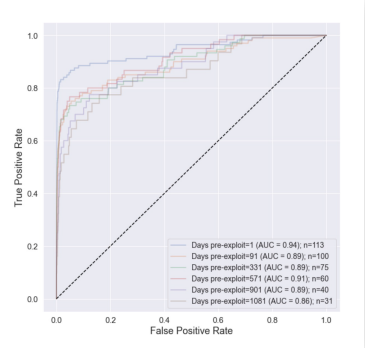


Fig. 6 ROC Curve for CVE Exploit Prediction Model

Our model assigns future-exploited CVEs a higher probability of exploit than not-exploited CVEs 89% of the time 3 months before exploitation was confirmed and 94% the day before.

3. IMPACT SCORE

In addition to evaluating the extent of current exploitation and the likelihood of future exploitation, Orpheus also examines the value of the assets on which the CVE occurs. For example, security cameras are often compromised via vulnerabilities and added to botnets, perhaps most famously in the case of the Mirai botnet. This is not ideal, but does not pose a substantial risk to the organisation itself. By contrast, vulnerabilities on Virtual Machine Management/Hypervisor software such as Citrix have been implicated in numerous ransomware campaigns.[4]

Orpheus has classified the software on which CVEs occur into risk categories, and this feeds into the overall prioritisation score alongside the evidence of active exploitation.

4. ADDITION OF THREAT INTELLIGENCE

As a cyber threat intelligence company, Orpheus has a large and constantly growing database of analyst-curated intelligence reports. We use our knowledge of threat actors exploiting CVEs to better understand the frequency and severity of attacks. We can also determine which specific threat actors are known to exploit which CVEs, and against which targets in different sectors and countries.

Adding threat intelligence provides context for the risks associated with a CVE and enhances an organisation's ability to prioritise patching for those CVEs that are known to be exploited by likely adversaries targeting them.

[4] Example: https://www.crowdstrike.com/blog/prophet-spider-exploits-citrix-sharefile/

5. PUTTING IT ALL TOGETHER: THE ORPHEUS VULNERABILITY SCORING SYSTEM

When prioritising security patches we must consider:

"Is this vulnerability actively exploited now?"	Ground Truth
"Is this vulnerability likely to be exploited soon?"	Exploit Prediction
"How bad would it be if this vulnerability were exploited?"	Impact Score

These measures are combined into our overall Orpheus Vulnerability Scoring System (OVSS) scores for CVEs.

The plot below shows the distribution of OVSS scores for all CVEs disclosed in or after 2016, as compared to CVSS scores. The distribution of OVSS scores reflects the underlying reality that most CVEs are not likely to be actively exploited.

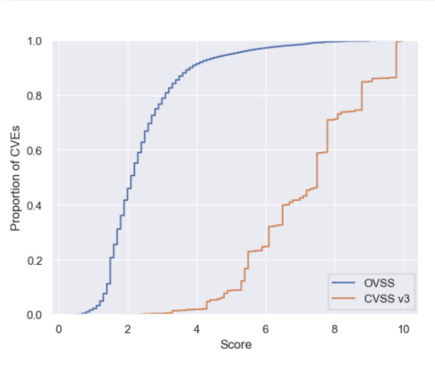


Fig. 7 ECDF Plot of CVSS and OVSS Scores for CVEs disclosed 2016+

Patching all CVEs with an OVSS >= 50 would mean only patching 5.2% of CVEs. This captures 100% of CVEs that have definitive evidence of exploitation, and 50% of CVEs which will be confirmed exploited in the next 30 days[5], as well as prioritising those with the highest impact potential.

Additionally, companies can choose their own risk threshold. For example, choosing to patch all CVEs that are confirmed exploited or have probability of exploit >= 25% would require patching 30% of CVEs, and would capture 87% of CVEs confirmed exploited in the next 30 days.[6]

By contrast, patching all CVEs with CVSS >= 9, requires patching 15.1% of CVEs, while capturing only 34% of confirmed-exploited CVEs.

Bottom line: OVSS offers huge efficiencies, allowing organisations to urgently patch the most widely-exploited, high-impact CVEs while needing to patch fewer CVEs overall.

[5] Based on the earliest OVSS score after CVE disclosure for the 32 CVEs, including zero-days, confirmed exploited between 2022-10-28 and 2022-11-28; OVSS scores increase as the exploit date approaches

[6] Based on model performance metrics on test data. This excludes zero-days, which by definition cannot be predicted in this way.

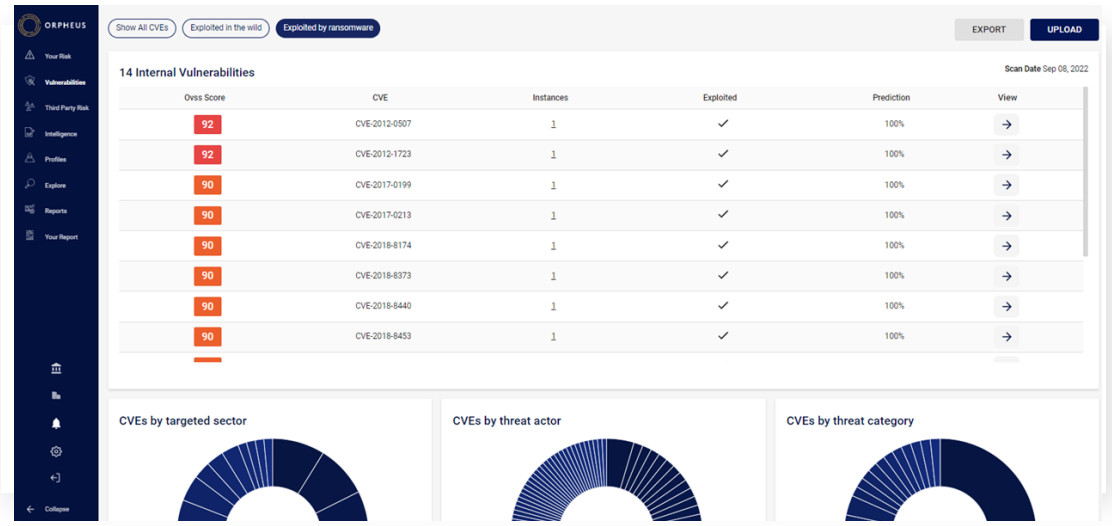
OUR SOLUTION - RISK BASED VULNERABILITY MANAGEMENT (RBVM) DASHBOARD

The Orpheus Risk Based Vulnerability Management dashboard incorporates the capabilities described in this paper to enable customers to patch the vulnerabilities that pose the highest risk to them.

The Orpheus Risk Based Vulnerability Management capability means that you can immediately focus on the tiny minority of CVE's that are a risk to you. By cancelling out the noise you can spend time and money dealing with the issues that really matter – significantly reducing cost and risk at the same time.

Features:

- OVSS (The Orpheus Vulnerability Scoring System) used to rank vulnerabilities and drastically improve the efficiency of patching efforts.
- Definitive list of which vulnerabilities are actually exploited – circa 0.5% of all vulnerabilities.
- Exploitation prediction.
- A connection to threat intelligence that details which adversaries are known to exploit which CVEs, the severity of the exploitation, and the targets involved.



Available via:

- Portal subscription – view your external facing vulnerabilities and upload internal scan results to prioritise vulnerabilities for remediation.
- API Integration – overlay Orpheus' data to your existing system in order to enhance it with risk based vulnerability management.

Visit **orpheus-cyber.com/platform/risk-based-vulnerability-management/** for more information.



Orpheus Cyber
Orpheus-cyber.com
contact@opheus-cyber.com

orpheus-cyber.com | 2022 Orpheus Cyber. All rights reserved